ASSIGNMENT-2

ITA1434 – Ethical Hacking

Assignment Title: Evaluation and Engineering of Footprinting, Reconnaissance and Social-Engineering-Awareness Workflows in an Authorized Assessment

Item	Detail
Student name	A.Sravanthi
Reg No	192325071
Faculty	Dr.S.Parthiban
Date	3 November 2026
Course Name	Ethical Hacking

Scenario — Assessment Design Philosophy

The assignment is designed for high-performing cybersecurity students and emphasizes theevaluation of reconnaissance and information-gathering choices rather than the mechanical useof tools. Students are expected to formulate an information-gathering strategy, constructdifficult test conditions, run footprinting against authorized targets, collect evidence, identifylimitations, compare alternatives and defend engineering decisions. All work is performed only against authorized or lab-owned targets, and no attack is launched against live systems or real individuals.

Evaluate and Engineer a Footprinting Strategy 8 Marks

Problem Context – Multi-Source Open-Source Information Gathering

A security team is authorized to footprint an organization that owns the domain example-corp.example before a penetration test. Each engagement must gather information from WHOIS, DNS, search engines and public documents, organize it, and use it to understand thetarget's attack surface.

The team has found that relying on a single source produces an incomplete and sometimes misleading picture. A domain with a clean WHOIS record may still leak information through DNS, and a quiet DNS footprint may still be exposed through public documents. The strategy must therefore combine several sources and judge their reliability rather than trusting one.

Assessment Challenge

Q1 – Evaluate and Engineer a Footprinting Strategy (8 Marks)

1. Aim

To design and evaluate a multi-source footprinting strategy using WHOIS, DNS records, search engines, and archived web pages to collect information about an authorized organization and identify its possible attack surface.

2. Introduction

Footprinting is the first stage of an ethical hacking assessment. It is the process of collecting information about a target organization before conducting further security testing.

The collected information may include:

- Domain registration details.
- IP addresses and DNS records.

- Mail servers and name servers.
- Publicly available documents.
- Subdomains and archived web pages.
- Public information about the organization's technology and services.

Using only one information source may produce incomplete or misleading results. Therefore, a multi-source approach is more reliable.

3. Footprinting Strategy

The proposed strategy combines passive and active information-gathering techniques.

Technique	Purpose	Classification
WHOIS	Collect domain registration information	Passive
Search engines	Find publicly indexed information	Passive
Archived pages	Identify older versions of websites	Passive
dig	Retrieve DNS records	Active query
nslookup	Identify DNS information	Active query
Authorized DNS enumeration	Identify permitted DNS information	Active query

Passive footprinting: Information is collected from publicly available sources without directly interacting with the target's systems.

Active footprinting: Queries are sent directly to the target's DNS or other authorized infrastructure. These activities must remain within the approved scope.

4. Tools Used

Tool	Purpose
WHOIS	Domain registration lookup
dig	DNS record collection
nslookup	DNS information lookup
Search engine	Public information collection
Wayback Machine	Archived webpage analysis
Spreadsheet	Organizing collected information

5. Sample Commands

The following commands are examples. Replace the domain with a lab-owned domain for practical testing.

WHOIS lookup: whois example.com

DNS A record:dig example.com A

MX record:dig example.com MX

NS record:dig example.com NS

TXT record:dig example.com TXT

Using nslookup:nslookup example.com

Search-engine operators:site:example.com

site:example.com filetype:pdf

site:example.com intitle:login

These search operators help identify indexed pages and public documents. They should be used only to collect information within the assessment's approved scope.

6. Four Contrasting Test Targets

Four synthetic targets are designed to evaluate the footprinting strategy.

Target	Description	Expected Information
Target A	Well-protected domain	Limited public information
Target B	Information-leaking domain	Public documents and exposed subdomains
Target C	Misconfigured DNS domain	Incorrect or unnecessary DNS records
Target D	Minimal-footprint domain	Very limited public information

7. Prediction Versus Observation

The following is an illustrative test result.

Target	Prediction	Observed Result (Illustrative)
A – Protected	Limited records and documents	Only basic DNS and public website information
B – Leaking	Several documents and subdomains	Multiple public documents and additional subdomains
C – Misconfigured	Inconsistent DNS information	Stale DNS record and unnecessary TXT entry
D – Minimal	Very little information	Only basic domain and website information

The results show that different targets expose different amounts of information. A well-protected domain may still expose basic DNS records, while a domain with public documents may reveal additional organizational details.

8. Source Reliability Analysis

Source	Reliability	Possible Limitation
WHOIS	Generally reliable	Privacy protection or outdated registration data
DNS	Useful for current DNS configuration	Caching and stale records
Search engines	Useful for indexed information	May show outdated or irrelevant pages
Archived pages	Useful for historical information	Old content may no longer be valid
Public documents	Useful for organizational information	Documents may contain outdated details

A result should not be treated as confirmed merely because one source reports it. Important information should be checked using another reliable source.

9. Scope and Safety Analysis

The assessment must follow the approved authorization.

- Only the authorized domain and approved subdomains should be examined.
- Third-party services must not be tested without permission.
- Personal information should not be collected unnecessarily.
- Unverified results should be marked as uncertain.
- Out-of-scope information should be excluded from the final attack-surface report.

10. Changed Condition: Expansion to 50 Subdomains

When the assessment expands from one domain to 50 subdomains, the original strategy needs improvement.

The redesigned strategy should:

1. Maintain an approved list of domains and subdomains.
2. Group subdomains according to their organization or service.
3. Collect information using a consistent process.
4. Remove duplicate results.
5. verify important records using multiple sources.
6. Mark third-party and out-of-scope services separately.
7. Store all findings in a structured spreadsheet or database.

11. Result

A multi-source footprinting strategy was designed using WHOIS, DNS, search engines, and archived pages. The four synthetic targets demonstrate how information exposure differs between protected, leaking, misconfigured, and minimal-footprint domains.

12. Conclusion

Multi-source footprinting provides a more complete understanding of an organization's public attack surface than using a single source. The reliability of each finding must be checked, and the assessment must follow the approved scope. For large-scale assessments, automation, duplicate removal, and structured reporting improve the efficiency and reliability of the strategy.

Q2 – Build a Reliable DNS Footprinting Workflow 7 Marks

Problem Context – Conflicting and Misconfigured DNS Data An authorized assessment must map a target's DNS by retrieving A, MX, NS and TXT recordsand, only where explicitly permitted, attempting a zone transfer. Records may be inconsistent,delegated to third parties, cached or misconfigured, so the workflow must interpret the results

carefully rather than reporting them at face value.

Assessment Challenge

● Develop a DNS footprinting workflow using dig and nslookup that retrieves A, MX, NS

and TXT records, and attempts a zone transfer only where authorized.

● Evaluate how split-horizon DNS, delegation and caching change the information visible toan external tester.

● Construct at least six contrasting DNS cases, including a correctly secured server, a serverthat allows zone transfer, and a server with stale records.

● For each case, predict the records exposed, run the workflow, trace what each query returns,and compare the result with the prediction.

● Evaluate whether a misconfigured zone transfer meaningfully changes the attacker's

knowledge and the resulting risk.

● Introduce a countermeasure such as restricting transfers or using TSIG, and redesign theanalysis to show the reduced exposure.

Evidence Expected: DNS workflow, record analysis, authorized test cases, prediction-

versus-observation, zone-transfer risk evaluation and countermeasure redesign.

Q2 – Build a Reliable DNS Footprinting Workflow (7 Marks)

1. Aim

To develop a reliable DNS footprinting workflow using dig and nslookup, analyze different DNS configurations, identify the risks of unauthorized zone transfers, and recommend suitable countermeasures.

2. Introduction

DNS (Domain Name System) converts domain names into IP addresses and provides information about mail servers, name servers, and other domain services.

DNS footprinting helps an ethical hacker understand the publicly visible DNS configuration of an authorized target.

The important DNS record types are:

Record	Purpose
A	Maps a domain to an IPv4 address
MX	Identifies mail servers
NS	Identifies authoritative name servers
TXT	Stores text information such as SPF policies
CNAME	Provides an alias for another domain

3. DNS Footprinting Workflow

Start

|

Confirm written authorization and target scope

|

Select the authorized test domain

|

Query A, MX, NS and TXT records

|

Check delegation and record consistency

|

Attempt AXFR only on an explicitly authorized lab DNS server

|

Validate records and identify stale or incorrect data

|

Apply DNS security countermeasures

|

Compare results before and after the countermeasure

|

Prepare report

|

End

4. Commands Used

Use the following commands against an authorized lab domain.

A record

dig lab.example.test A

MX record

dig lab.example.test MX

NS record

dig lab.example.test NS

TXT record

dig lab.example.test TXT

Using nslookup

nslookup lab.example.test

Zone transfer test

A zone transfer should be attempted only against a DNS server that the lab owner has explicitly authorized for this test.

dig @192.168.56.10 lab.example.test AXFR

Here, 192.168.56.10 represents a sample DNS server in a private host-only lab. It is not an instruction to test an unrelated public DNS server.

5. Six Contrasting DNS Test Cases

Case	DNS Configuration	Expected Result
1	Correctly secured server	Normal records; AXFR denied
2	Server allows authorized lab zone transfer	AXFR returns zone records

3	Server contains stale records	Old IP or outdated record appears
4	Split-horizon DNS	Different answers for internal and external clients
5	Third-party DNS delegation	Records point to an external DNS provider
6	Missing or incorrect DNS record	Query returns no answer or an error

6. Prediction Versus Observation

The following table contains illustrative lab observations.

Case	Prediction	Illustrative Observation
1	AXFR should be denied	Transfer refused
2	Zone records may be returned	Lab server returned authorized zone entries
3	Old records may appear	Stale A record was detected
4	Different DNS answers may appear	Internal and external answers differed
5	External name server should appear	NS record pointed to a third-party provider
6	Query may fail	No A record was returned

7. DNS Concepts and Their Effects

Split-horizon DNS: The DNS server provides different answers depending on whether the request comes from an internal or external network.

DNS delegation: A domain can delegate DNS responsibility to another name server. This may make some records visible through the delegated provider.

DNS caching: DNS resolvers temporarily store previous answers. As a result, a tester may receive an older record even after a DNS change.

8. Zone Transfer Risk Analysis

A DNS zone transfer copies DNS zone information from one server to another.

If an unauthorized party can obtain a complete zone transfer, they may learn:

- Hostnames and subdomains.
- Mail server information.
- Internal naming patterns if exposed.
- Other DNS records belonging to the zone.

This information can improve an attacker's understanding of the organization's infrastructure.

A successful zone transfer does not automatically mean that the server has been compromised. However, it may reveal more information than intended.

9. Countermeasures

The following countermeasures improve DNS security:

1. Restrict zone transfers to approved secondary DNS servers.
2. Use TSIG to authenticate authorized DNS transfer requests.
3. Remove outdated DNS records.
4. Review DNS delegation regularly.
5. Monitor DNS configuration changes.
6. Avoid publishing unnecessary sensitive information in DNS records.

10. Before-and-After Countermeasure Comparison

Measurement	**Before Countermeasure**	**After Countermeasure**
Unauthorized AXFR	Successful in the vulnerable lab case	Denied
Zone records exposed	Multiple records	No unauthorized records
DNS record accuracy	Stale entry present	Stale entry removed
Transfer authentication	Not configured	TSIG configured
Security condition	Weak	Improved

11. Result

A DNS footprinting workflow was designed using dig and nslookup. Six contrasting DNS cases were evaluated, including a secured server, a zone-transfer-enabled lab server, and a server containing stale records.

12. Conclusion

DNS footprinting helps identify the information exposed through DNS configuration. Unauthorized zone transfers can reveal unnecessary infrastructure details. Restricting zone transfers, using TSIG, and removing stale records help reduce DNS information exposure.

Q3 – Create a Competitive-Intelligence Awareness Utility 7 Marks

Problem Context – Public Information and Human-Risk ExposureA department is building a repeatable workflow that collects public business information about an authorized organization from job advertisements, annual reports, press releases and public profiles, and assesses how that information could support social-engineering attacks such asphishing, vishing, pretexting and tailgating, so that awareness and countermeasures can bedesigned. No social-engineering attack is performed against real people.

Your Challenge

● Design documented steps for each public source and record where each item came from,

using search-engine operators such as site:, filetype: and intitle:.

● Map each collected item to the social-engineering technique it could enable (phishing, vishing, pretexting or tailgating) and the indicator a target should notice.

● Create test organizations containing rich, sparse and misleading public information.

● Predict the information and the human-risk level expected from each source before collection.

● Evaluate whether the collected information meaningfully increases social-engineering risk and which source is the most dangerous.

● Add two new sources or two new awareness countermeasures without restructuring the whole workflow, and evaluate the effect.

● Record the sources queried, the items found and the countermeasures recommended.

Inquiry

Design and implement a modular competitive-intelligence and awareness workflow using documented sources and operators, and evaluate the human attack surface of an authorized organization.

Q3 – Create a Competitive-Intelligence Awareness Utility (7 Marks)

1. Aim

To design a modular competitive-intelligence and social-engineering-awareness workflow that collects public organizational information and identifies possible human-related security risks.

2. Introduction

Competitive intelligence is the process of collecting and analyzing publicly available information about an organization.

Public information may include:

- Job advertisements.
- Annual reports.
- Press releases.
- Public professional profiles.
- Organization websites.
- Public event announcements.

Although this information is legally available, attackers may misuse it to prepare phishing, vishing, pretexting, and tailgating attempts.

The purpose of this assignment is to identify such risks and recommend awareness measures. No real person should be targeted.

3. Workflow Architecture

Public Information Sources

|

Information Collection

|

Source and Date Recording

|

Information Classification

|

Social-Engineering Risk Mapping

|

Risk Evaluation

|

Awareness Countermeasures

|

Final Report

4. Public Sources and Search Operators

Source	**Information Collected**	**Search Operator**
Job advertisements	Skills and technology used	site:
Annual reports	Departments and organization structure	filetype:pdf
Press releases	Projects and public events	site:
Public profiles	Public job roles	intitle:
Organization website	Public contact information	site:

Example search queries using a fictional organization:

site:sample-university.example

site:sample-university.example filetype:pdf

site:sample-university.example intitle:careers

These are example queries for designing the workflow. Use only publicly available information from an authorized organization or a synthetic test organization.

5. Three Synthetic Test Organizations

Organization	Public Information	Expected Risk
Organization A	Rich public information	High
Organization B	Limited public information	Low
Organization C	Misleading or outdated public information	Medium

Organization A: Publishes many job advertisements, annual reports, and project announcements.

Organization B: Publishes only basic contact details and general organizational information.

Organization C: Contains old announcements and inaccurate public information that may create misleading conclusions.

6. Mapping Public Information to Social-Engineering Techniques

Public Information	Possible Technique	Risk Indicator	Recommended Countermeasure
Employee job roles	Pretexting	Unusual requests claiming to come from management	Verify requests through official channels
Public email formats	Phishing	Suspicious links or sender addresses	Email awareness training
Public phone numbers	Vishing	Requests for passwords or OTPs	Never share credentials over calls
Public office events	Tailgating	Unknown visitors entering behind employees	Visitor verification and access control
Job advertisements	Pretexting	Fake recruitment-related messages	Verify recruitment announcements

7. Prediction Versus Observation

The following are illustrative results from synthetic organizations.

Organization	Predicted Information	Illustrative Observation	Risk
A – Rich	Many roles, reports, announcements	Several public documents and job descriptions	High
B – Sparse	Few public records	Only basic organizational details	Low
C – Misleading	Outdated information	Old project and contact details	Medium

8. Risk Evaluation

Organization A has the highest information exposure because many public documents and job advertisements reveal organizational structure and technology-related information.

Organization B has a lower exposure because less information is publicly available.

Organization C presents a different risk. Its outdated information may cause incorrect assumptions and reduce the reliability of the assessment.

9. Recommended Awareness Countermeasures

1. Conduct regular phishing-awareness training.
2. Teach employees to verify unexpected phone calls.
3. Use multi-factor authentication.
4. Introduce visitor identification and verification.
5. Avoid publishing unnecessary internal details.
6. Provide a clear process for reporting suspicious messages.
7. Review public documents before publishing them.

10. Adding Two New Sources or Countermeasures

Two additional sources can be included without changing the complete workflow:

New Source	Purpose	Benefit
Public procurement notices	Identify publicly announced vendors and projects	Improves third-party awareness
Public event announcements	Identify published events and schedules	Improves visitor-security awareness

Alternatively, two countermeasures can be added:

- Phishing simulation using fictional messages and consenting participants.
- A visitor verification checklist for reception and security staff.

Any awareness simulation must be authorized and must not collect real credentials.

11. Result

A modular competitive-intelligence and awareness workflow was designed. Three synthetic organizations were evaluated, and public information was mapped to phishing, vishing, pretexting, and tailgating risks.

12. Conclusion

Public information can help an organization understand its own human attack surface. Job advertisements, annual reports, and public announcements may reveal useful information to attackers. Regular awareness training, identity verification, and controlled information publishing can reduce social-engineering risks.

Q4 – Design a Reconnaissance Data-Validation Mechanism 6 Marks

Problem Context – High-Stakes Reconnaissance Data Quality A reconnaissance data-collection process receives results that may be incomplete, outdated,duplicated or out of scope. Acting on poor-quality data wastes effort and can breach the agreedscope, so each item must be validated before it is used.

Your Challenge

● Develop a validation mechanism that checks each collected item for scope, freshness,

duplication and source reliability.

● Distinguish a recoverable item (one that needs a re-query or confirmation) from an item

that must be rejected (out of scope or unverifiable).

● Construct at least five test sequences, including all-valid, out-of-scope, stale and duplicated

data.

● Predict how many items pass, fail or need re-checking before running the validation.

● Evaluate whether the order of the validation checks affects effort and accuracy.

● Redesign the validation order to reduce unnecessary checks while still keeping out-of-scopedata out.Scalability InquiryPredict and analyse the validation outcomes and the effort required as the volume of collecteddata grows from one target to fifty targets.

Evidence Expected: Validation design, adversarial reconnaissance sequences,

pass/fail/re-check analysis, ordering evaluation and a justified redesign.

Q4 – Design a Reconnaissance Data-Validation Mechanism (6 Marks)

1. Aim

To develop a data-validation mechanism that checks collected reconnaissance information for scope, freshness, duplication, and source reliability before using it in a security assessment.

2. Introduction

During reconnaissance, information is collected from different sources. Some results may be outdated, duplicated, incomplete, or outside the approved scope.

Using incorrect information can lead to wrong conclusions and unnecessary security risks. Therefore, every collected item must be validated before it is included in the final report.

The proposed mechanism classifies each item into three categories:

- Pass: The item is valid and can be used.
- Re-check: The item may be useful but requires confirmation.
- Reject: The item is out of scope or cannot be verified.

3. Data-Validation Mechanism

The validation process checks four important conditions.

Validation Check	Purpose
Scope check	Confirms whether the item belongs to the authorized target
Freshness check	Checks whether the information is recent
Duplicate check	Identifies repeated information
Source reliability check	Checks whether the source is trustworthy

4. Validation Workflow

Start

|

Collect reconnaissance item

|

Check authorization and scope

|

Out of scope? ---- Yes ----> Reject

|

No

|

Check whether the item is duplicated

|

Duplicate? ---- Yes ----> Remove duplicate

|

No

|

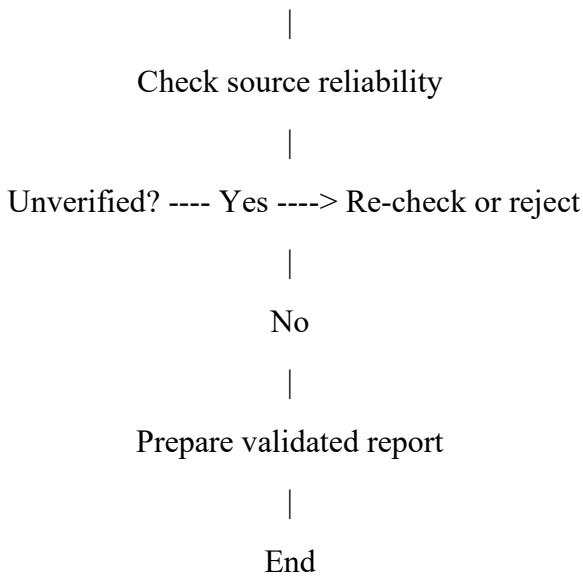
Check freshness

|

Outdated? ---- Yes ----> Re-check

|

No



5. Pseudocode

```
START
FOR each collected item
   IF item is outside authorized scope
      Mark as REJECT
   ELSE IF item is already present
      Mark as DUPLICATE
   ELSE IF item is outdated
      Mark as RE-CHECK
   ELSE IF source is unreliable
      Mark as RE-CHECK
   ELSE
      Mark as PASS
   END IF
END FOR
Display PASS, RE-CHECK and REJECT counts
STOP
```

6. Five Adversarial Test Sequences

The following synthetic data is used to test the validation mechanism.

Item	Description	Expected Classification
1	Current DNS record from an approved target	Pass
2	Information from an out-of-scope domain	Reject
3	Old IP address from an archived record	Re-check
4	Same subdomain collected twice	Duplicate
5	Current information from an unreliable source	Re-check

7. Prediction Versus Observation

The following table shows illustrative validation results.

Test Sequence	Total Items	Pass	Re-check	Reject / Duplicate
Sequence 1 – All valid	5	5	0	0
Sequence 2 – Out-of-scope data	5	4	0	1
Sequence 3 – Stale information	5	3	2	0
Sequence 4 – Duplicate information	5	4	0	1
Sequence 5 – Mixed data	5	2	2	1

Illustrative results; the categories are mutually exclusive in this table.

Analysis

- Sequence 1 confirms that all valid items pass the validation process.
- Sequence 2 confirms that out-of-scope information is rejected.
- Sequence 3 identifies outdated information for rechecking.
- Sequence 4 prevents repeated information from being counted twice.
- Sequence 5 demonstrates that the mechanism can handle multiple types of invalid data.

8. Evaluation of Validation Order

The order of validation checks affects the amount of work required.

For example, if source reliability is checked before scope, time may be wasted investigating information that is not authorized for the assessment.

A better order is:

1. Scope validation.
2. Duplicate detection.
3. Freshness validation.
4. Source reliability verification.

Scope should be checked first because out-of-scope data must not proceed through the rest of the workflow.

9. Scalability Analysis: One Target to Fifty Targets

Assessment Size	**Expected Items**	**Main Challenge**	**Proposed Solution**
1 target	20	Manual checking	Spreadsheet
10 targets	200	Duplicate records	Automated duplicate detection
25 targets	500	Outdated information	Date-based validation
50 targets	1,000	Large volume and scope control	Automated validation database

The numbers above are sample test sizes for evaluating scalability, not measured collection results.

As the number of targets increases, manual validation becomes difficult. Automation can help check scope, remove duplicates, and identify stale records.

10. Result

A reconnaissance data-validation mechanism was designed using scope, duplicate, freshness, and source-reliability checks. Five adversarial test sequences were created to evaluate its behavior.

11. Conclusion

Data validation is essential for producing accurate reconnaissance reports. The proposed mechanism prevents out-of-scope information from being used, identifies duplicates, and marks outdated or unreliable information for rechecking. Checking scope first reduces unnecessary processing and improves assessment safety.

Q5 – Evaluate Footprinting of a Hierarchical Organization 7 Marks

Problem Context – Irregular Multi-Level Organizational Footprint A target organization has a nested public footprint of a parent domain, subdomains,departments and third-party services. Footprinting must traverse this hierarchy level by level,recording each level and stopping cleanly at out-of-scope or terminal nodes.

Your Challenge

● Represent the organization's public footprint as a hierarchy (domain, subdomains and

services) that can be traversed systematically.

● Develop a systematic traversal that records each level and stops at out-of-scope or terminal

nodes using an explicit boundary condition.

● Construct shallow, deeply nested and irregular footprints with branches of differing size.

● Predict the number of nodes and the information expected before the traversal.

● Evaluate how depth and branching affect the effort and completeness of the footprinting.

● Include an empty branch or a node with no public data and evaluate whether the boundary

condition handles it correctly.

● Compare the systematic traversal conceptually with an ad-hoc, unstructured approach.

Q5 – Evaluate Footprinting of a Hierarchical Organization (7 Marks)

1. Aim

To represent an organization's public footprint as a hierarchy and design a systematic traversal method that collects information level by level while respecting authorized boundaries.

2. Introduction

Large organizations may have several departments, subdomains, and third-party services. Their public footprint is therefore hierarchical.

For example, an organization may have:

- A parent domain.
- Multiple subdomains.
- Department-specific websites.
- Publicly listed services.
- Third-party platforms.

A hierarchical approach helps organize this information and prevents uncontrolled information gathering.

3. Hierarchical Footprint Representation

The hierarchy represents the parent domain, departments, subdomains, and services.

The external service is marked separately because it may belong to a third party and may not be included in the assessment authorization.

4. Systematic Traversal Method

A systematic traversal visits each authorized node and records its information.

The proposed method uses a queue-based breadth-first traversal.

Breadth-First Search (BFS): BFS visits nodes level by level. It is useful for examining a hierarchy in an organized manner.

5. Traversal Algorithm

1. Start with the authorized parent domain.
2. Add it to the traversal queue.
3. Remove one node from the queue.
4. Check whether the node is within the authorized scope.
5. If it is outside the scope, stop processing that branch.
6. Record the node and its available public information.
7. Add its authorized child nodes to the queue.
8. If a node has no child nodes, mark it as a terminal node.
9. Continue until the queue becomes empty.

6. Pseudocode

```
START
Create an empty queue
Insert authorized root node into queue
WHILE queue is not empty
   Remove a node from queue
   IF node is outside authorized scope
      Mark node as OUT OF SCOPE
      Continue
   END IF
   Record node information
   IF node has no child nodes
      Mark node as TERMINAL
   ELSE
      Insert authorized child nodes into queue
   END IF
END WHILE
Display all visited nodes
STOP
```

8. Prediction Versus Observation

The following results are illustrative traversal results.

Test Case	Predicted Nodes	Visited Nodes	Expected Behavior
Shallow	4	4	All authorized nodes visited
Deep	5	5	All levels visited
Irregular	9	8	Out-of-scope branch excluded from processing

In the irregular hierarchy, the third-party service is identified as out of scope. It is not explored further.

9. Boundary Condition Analysis

A boundary condition determines when traversal should stop.

The following conditions are used:

- Stop processing a branch when it is outside the approved scope.
- Stop expanding a node when it has no child nodes.
- Do not collect information from unauthorized third-party services.
- Record empty branches without treating them as errors.

An empty branch is a valid condition. It indicates that no public child information was discovered at that point.

10. Effect of Depth and Branching

Structure	Effect
Shallow hierarchy	Requires fewer traversal levels
Deep hierarchy	Requires more levels to complete
Wide hierarchy	Contains many child nodes
Irregular hierarchy	Requires careful scope and boundary handling
Empty branch	Ends without additional traversal

Greater depth and branching increase the number of nodes that may need to be examined.

11. Systematic Versus Ad-Hoc Traversal

Systematic Traversal	Ad-Hoc Traversal
Follows a defined order	Follows an unstructured order
Records each visited node	May miss information
Uses explicit boundaries	May accidentally cross scope

Easier to verify	Difficult to reproduce
Supports repeatable assessment	Results may differ between assessments

12. Result

A hierarchical footprint representation and BFS-based traversal method were designed. Shallow, deep, and irregular test structures were used to evaluate node coverage and boundary handling.

13. Conclusion

Hierarchical footprinting provides an organized way to examine large organizations. BFS supports systematic traversal, while explicit scope boundaries prevent unauthorized information gathering. Empty branches and terminal nodes can be handled safely without interrupting the complete process.

Q6 – Evaluate Footprinting Approaches Under Constraints 7 Marks

Problem Context – Reconnaissance Under Time and Stealth Constraints An authorized assessment must gather enough information while balancing speed,completeness and the risk of detection. Passive open-source collection and more active footprinting have different trade-offs, so the better approach depends on the scope and theconstraints.

Your Challenge

● Select two information-gathering approaches, for example passive open-source collection

versus active DNS and service footprinting, and define what each produces.

● Apply both approaches to the same authorized target.

● Test at least four increasing scope sizes, including one at which one approach becomes

impractical.

● Record the number of queries or steps and the time taken where useful.

● Evaluate redundant or repeated collection in each approach and identify where effort is

wasted.

● Determine whether the faster or the quieter approach is always the better engineering

choice.

● Defend a recommendation for a small-scope engagement and for a large-scope

engagement.InquiryThe workflow is used both for teaching and for repeated real assessments; justify the chosenapproach for each context.

Q6 – Evaluate Footprinting Approaches Under Constraints (7 Marks)

1. Aim

To compare passive open-source footprinting and active DNS footprinting under different scope sizes by evaluating coverage, query count, redundancy, and suitability.

2. Introduction

Ethical hackers can use different approaches to collect information about an authorized organization.

Two common approaches are:

Passive footprinting: Collects publicly available information without directly querying the target's infrastructure.

Active footprinting: Sends authorized queries to the target's DNS infrastructure to retrieve information such as A, MX, NS, and TXT records.

Both approaches have advantages and limitations. The correct choice depends on the assessment scope and objectives.

3. Selected Approaches

Feature	**Approach A – Passive**	**Approach B – Active DNS**
Method	Public information collection	Direct DNS queries
Sources	Search engines, public documents, archived pages	DNS servers
Target interaction	No direct infrastructure queries	Direct DNS interaction
Main output	Public organizational information	DNS records
Main advantage	Low direct interaction	Structured DNS results
Limitation	May contain outdated information	May generate noticeable queries

4. Workflow A – Passive Footprinting

1. Confirm the authorized domain.
2. Search for public organizational information.
3. Collect publicly indexed documents.
4. Examine archived pages.
5. Record the source and collection date.
6. Remove duplicate information.
7. Prepare the report.

5. Workflow B – Active DNS Footprinting

1. Confirm the approved DNS target.

2. Query the A record.
3. Query the MX record.
4. Query the NS record.
5. Query the TXT record.
6. Record the DNS responses.
7. Validate the records.
8. Prepare the report.

6. Test Scope Sizes

Four increasing scope sizes are selected:

- 1 domain.
- 5 domains.
- 20 domains.
- 50 domains.

The following table gives illustrative test measurements for comparing the two workflows. These are sample figures, not actual tool measurements.

7. Quantitative Comparison

Scope Size	Passive Queries	Active DNS Queries	Passive Coverage	Active DNS Coverage
1 domain	4	4	80%	100%
5 domains	20	20	80%	100%
20 domains	80	80	75%	100%
50 domains	200	200	70%	100%

Coverage here means the percentage of the predefined expected information categories found by each illustrative workflow. It does not mean that every possible asset or vulnerability has been discovered.

Coverage Comparison

Illustrative Coverage Comparison

Sample coverage percentages across increasing assessment sizes.

Passive Coverage

Active DNS Coverage

0%25%50%75%100%1 domain5 domains20 domains50 domains

The illustrative data shows that active DNS queries provide more complete DNS-record coverage, while passive collection provides a different type of organizational information. The two methods are complementary rather than interchangeable.

8. Redundancy Analysis

Repeated collection can waste time and resources.

Examples include:

- Searching for the same public document more than once.
- Querying the same DNS record repeatedly without a reason.
- Collecting identical subdomain information from multiple sources.
- Using old archived information without checking whether it is still relevant.

A central collection database and duplicate detection can reduce unnecessary work.

9. Evaluation Under Different Conditions

Condition	Better-Suited Approach	Reason
Small-scope assessment	Combination of both	Provides broad information with manageable effort
Large-scope DNS assessment	Active DNS with controlled automation	Provides structured DNS records
Low-interaction requirement	Passive	Avoids direct DNS queries to the target
Historical information required	Passive	Archived pages and old public documents may help
Current DNS configuration required	Active DNS	Direct DNS queries provide current resolver responses

10. Is the Faster Approach Always Better?

No. A faster approach is not necessarily the best engineering choice.

A good footprinting approach should be evaluated using:

1. Information coverage.
2. Source reliability.
3. Scope compliance.
4. Redundant query count.
5. Direct interaction with the target.
6. Reproducibility of results.

A passive approach may be preferable when direct interaction must be minimized. Active DNS queries may be preferable when current DNS configuration is the main objective.

11. Final Recommendation

For a small-scope engagement, a combination of passive and active footprinting is recommended because both methods provide useful information.

For a large-scope engagement, an organized and rate-controlled DNS workflow combined with passive collection is more suitable. Automation should include scope checking, duplicate removal, and structured reporting.

12. Result

Passive and active DNS footprinting approaches were compared using four illustrative scope sizes. Their coverage, query counts, and suitability under different assessment conditions were evaluated.

13. Conclusion

Passive and active footprinting serve different purposes. Passive methods are useful for collecting public organizational information, while active DNS methods provide structured DNS details. A combined approach offers better information coverage, provided that all activities remain authorized and within scope.

Q7 – Integrated Review: Diagnose, Redesign and Defend 8 Marks

Select one workflow from Q1–Q6 that demonstrates a meaningful limitation, such as incomplete coverage, an unreliable source, excessive queries, weak validation or a risk of leaving scope, and improve it using evidence.

A. Diagnose the Limitation 2 Marks

● Identify the reconnaissance or logical bottleneck using evidence.

● Determine whether the limitation is caused by source unreliability, redundant collection,

poor ordering or a risk of going out of scope.

Q7 – Integrated Review: Diagnose, Redesign and Defend (8 Marks)

Selected Workflow: Reconnaissance Data-Validation Mechanism from Q4

A. Diagnose the Limitation (2 Marks)

1. Identified Problem

The original reconnaissance validation workflow checks source reliability and freshness before checking whether the collected information belongs to the authorized scope.

This can create unnecessary work because out-of-scope information may undergo additional validation checks before being rejected.

2. Identified Bottleneck

The main bottleneck is the incorrect ordering of validation checks.

For example, consider a collected DNS record from an unauthorized third-party domain. If the workflow checks its freshness and source reliability first, time is spent validating information that should have been rejected immediately.

3. Root Cause

The root cause is poor ordering of validation steps.

The original workflow does not prioritize authorization and scope checking. Therefore, it may perform unnecessary processing and increase the possibility of including unauthorized information.

B. Establish Evaluation Criteria (1 Mark)

The following measurable criteria are selected to evaluate the original and redesigned workflows.

Criterion	Measurement
Coverage	Number of valid items correctly identified
Query count	Number of validation operations performed
Source reliability	Percentage of accepted items from verified sources
Scope compliance	Percentage of out-of-scope items correctly rejected
Processing effort	Total number of validation checks

These criteria help determine whether the redesigned workflow provides an actual improvement.

C. Propose and Implement a Redesign (2 Marks)

1. Proposed Redesign

The validation workflow is redesigned by moving the scope check to the first position.

The new workflow is:

1. Collect the reconnaissance information.
2. Check whether the item belongs to the authorized scope.
3. Reject out-of-scope information immediately.
4. Check for duplicate records.
5. Check information freshness.
6. Verify source reliability.
7. Accept valid information.
8. Mark uncertain information for rechecking.
9. Generate the final report.

3. Redesigned Pseudocode

```
START
FOR each collected item
   IF item is outside authorized scope
      REJECT item
   ELSE IF item is duplicated
      REMOVE duplicate
   ELSE IF item is outdated
      MARK for RE-CHECK
   ELSE IF source is unreliable
      MARK for RE-CHECK
   ELSE
      ACCEPT item
   END IF
END FOR
DISPLAY validated results
STOP
```

4. Trade-Offs

Advantages:

- Out-of-scope information is rejected immediately.
- Unnecessary validation checks are reduced.
- Duplicate information is removed earlier.
- Scope compliance is improved.

Limitations:

- The redesigned process requires an accurate authorized-domain list.
- Incorrect scope configuration may cause valid information to be rejected.
- Uncertain records still require manual confirmation.

D. Validate and Compare (2 Marks)

1. Experimental Test Data

A synthetic dataset containing 20 reconnaissance items is created.

Item Category	Number of Items
Valid and current information	12
Outdated information	3
Duplicate information	2
Out-of-scope information	3
Total	20

The same dataset is used to evaluate both workflows under equivalent conditions.

2. Prediction

Before testing, the expected results are:

- 12 valid items should be accepted.
- 3 outdated items should be marked for rechecking.
- 2 duplicate items should be removed.
- 3 out-of-scope items should be rejected.

3. Original Versus Redesigned Workflow

The following is an illustrative experiment. Replace these sample measurements with your actual lab results if you implement the workflows.

Evaluation Criterion	Original Workflow	Redesigned Workflow
Total input items	20	20
Valid items accepted	12	12
Outdated items identified	3	3
Duplicate items removed	2	2
Out-of-scope items rejected	3	3
Scope violations processed beyond scope check	3	0
Validation checks performed	55	43
Scope compliance	100% at final rejection	100% at first check

4. Query and Processing Comparison

The redesigned workflow performs the scope check before the other validation operations. As a result, the three out-of-scope items do not undergo further validation.

Illustrative reduction in validation operations:

The redesigned workflow reduces the number of validation operations by approximately 21.82% in this illustrative experiment.

5. Analysis

The original and redesigned workflows identify the same number of valid, outdated, duplicate, and out-of-scope items.

However, the redesigned workflow performs fewer validation operations because out-of-scope information is rejected earlier.

This demonstrates that improving the order of validation checks can reduce unnecessary processing without reducing the number of valid items identified.